Deval Kotak

Mumbai, India | devalktk@gmail.com | github.com/devalkotak | linkedin.com/in/devalkotak | devalkotak.github.io

I work where the problem lives: inside the team that owns the system, learning how it really runs, finding where it is exposed, and building the fix alongside them. What I leave behind is a working control they own, not a findings report.

SKILLS

Cloud & Infrastructure Security: AWS, IAM, Least Privilege, Terraform, CIS AWS Foundations Benchmark, Policy as Code, CloudTrail, GuardDuty, S3, EC2, VPC, Security Groups

Secure SDLC & Integration: SAST, SCA, DAST, CI/CD Security Scanning, GitHub Actions, SARIF, Threat Modeling (STRIDE), Jira, GitHub and Slack API Integrations

Identity & Governance: User Access Review, Access Recertification, Access Governance, ISO 27001 Control Mapping, Risk Assessment, CIS Benchmarks

Application Security: Penetration Testing, VAPT, OWASP Top 10, Web Application Security, API Security Testing, Vulnerability Assessment

Detection & Response: SIEM, Alert Rule Tuning, False-Positive Reduction, DLP, Incident Triage, Threat Intelligence

AI & Automation: Multi-Agent Security Automation, Claude Code (custom skills with evals), Gemini API, LLM Structured Output

Languages: Python, Bash, SQL, JavaScript (Node.js)

Security Tools: Burp Suite, OWASP ZAP, Nuclei, Nmap, Wireshark, Postman, Coralogix

EXPERIENCE

JioStar (Mumbai, India)

Cybersecurity Intern *Feb 2026 – Aug 2026*

- Built the quarterly User Access Review workflow for 6,000+ users across 650+ apps with the GRC team and app owners, automating reminders, approvals, evidence collection and fulfillment tracking; designed & built for org-wide rollout.
- Shipped an automated regression testing engine integrated with Jira and GitHub that cut security test-case creation from 2 hours to 20 seconds, turning regression testing into a standing capability instead of a manual one-off.
- Created Slackbots and Chrome extensions that automate recurring security workflows, removing repetitive manual steps from daily operations.
- Conducted API security testing and VAPT for internal tools, identifying exploitable flaws and documenting remediation steps for the owning teams.
- Contributed to a multi-agent VAPT system that runs automated SAST and validation, catching issue classes that manual review misses and widening coverage across the codebase.
- Delivered an API inventory scanner that discovers and maps exposed endpoints across production, giving the team visibility into attack surface.
- Designed a triage layer over the existing SIEM, built against 100+ alert definitions, that automatically classifies DLP & InfraSec Alerts and filters false positives, cutting the noise analysts review before a real alert surfaces.
- Developed a persistent Telegram crawler fleet that passively monitors channels for piracy intelligence, surfacing 282 confirmed threats across 167,000+ messages scanned in 5 days without manual searching.

PROJECTS

AWS Control Mapping & Risk Register *AWS, GRC*

- Deployed a small AWS environment (EC2, S3, IAM, VPC) and built a risk register mapping each asset to realistic threats, likelihood, and impact based on the actual configuration.
- Mapped the environment against CIS AWS Foundations Benchmark and ISO 27001 controls, documenting evidence and pass/fail status for each control.

IaC Misconfiguration Scanner *Python, Terraform*

- Developed a scanner that parses Terraform configuration files and flags misconfigurations against CIS AWS Foundations Benchmark controls before deployment.
- Tested the scanner against real infrastructure from the AWS risk-register project, confirming it caught the same misconfigurations identified manually.

Reachability CVE Triage *Python*

- Built a dependency-vulnerability triage tool that ranks findings by whether application code can actually reach the vulnerable path, using an AST import graph and route detection to filter out unreachable CVEs that would otherwise waste triage time.
- Pulls live data from OSV and CISA KEV and emits SARIF and JSON so results drop straight into CI code-scanning; packaged as a reusable GitHub Action.
- Modeled the tool's own attack surface with STRIDE, mapping trust boundaries across untrusted repository input, third-party advisory feeds, and SARIF output, then fixed six of the seven findings with regression tests and documented the reasoning for the one accepted.

CIS Compliance Checker *Python*

- Wrote a policy-as-code tool that checks a machine's configuration against CIS Benchmark controls and reports pass or fail against each control ID, turning a manual audit checklist into an automated scan.
- Structured it as pluggable modules, starting with the Windows baseline and leaving clean extension points for macOS, Linux, and AWS.

LLM Red Team & Defense Lab (In Progress) *Python, LangChain*

- Building an attack-and-defense lab against a deliberately vulnerable LangChain ReAct agent, organized around the OWASP Top 10 for LLM Applications (2025): prompt injection, system prompt leakage, insecure output handling, and excessive agency.
- Reviewed the agent's tool layer and identified an IDOR in its transaction tool, raw SQL built from model-supplied input, and authorization enforced only by the system prompt; next step is reproducing each exploit, adding a guardrail library, and re-testing.

EDUCATION

Dwarkadas J. Sanghvi College of Engineering (Mumbai, India) | CGPA: 8.01
B.Tech, Computer Science and Engineering (IoT, Cybersecurity and Blockchain Technology) *June 2026*

CERTIFICATIONS

HTB Certified Web Exploitation Specialist (CWES): In Progress (currently pursuing, not yet certified)

LEADERSHIP EXPERIENCE

DJS ISACA (Mumbai, India)
Vice President *Jul 2024 – Aug 2025*

- Designed web exploitation and cryptography challenges simulating OWASP Top 10 vulnerabilities for the Breachbytes 2.0 CTF (80+ participants) and ran the technical infrastructure and secure API integrations for SYN3ERGY 2.0, a 24-hour intercollege hackathon.
- Taught hands-on ethical hacking and network security sessions to 80+ students on Burp Suite and Wireshark, covering practical exploitation and traffic analysis.
- Planned the committee's technical events end to end and conducted 80+ interviews to build the next core team.

Optiverse – Student Led Organization (Global, Remote)
Co-Founder *Mar 2021 – Present*

- Directed strategy and operations for a 250+ member organization across 19 countries, building the programs and structure that keep it running.
- Ran 90+ educational workshops (50–250 participants) and two 2-month internship programs at an 8% acceptance rate, aimed at students aged 11–17.
- Partnered with NGOs including Lakshya and Lotus Petal Foundation, earning recognition from Lady Gaga's Born This Way Foundation.

DJS Trinity (Mumbai, India)
Co-Chairperson *Aug 2024 – Apr 2025*

- Led a 150+ person team across the tenure, running a 3-day college festival spanning inter- and intra-college technical, non-technical, and sports competitions, and owning budget, logistics, venue production, and security for 1000+ attendees per night.
- Managed artist bookings, sponsorships, and fundraising throughout the tenure, and coordinated crowd control and police permissions to keep the festival running smoothly at scale.
- Oversaw social media coverage, creation, management and launched new event formats including a national-level drone race, coordinating external vendors and publicity.